

VideoFly 网站全量质量检查

阶段总结（累计更新至第 3 阶段）

审计目标	保障网站正常使用；检查前后端一致性、安全、Bug、鉴权与调用链路
当前进度	6 个阶段中已完成 3 个：探索、质量制品生成、代码审查
当前状态	确认 6 个问题：2 个高、3 个中、1 个低；尚未修改产品源码
下一阶段	第 4 阶段规格审计：独立复核并确认设计、政策和部署意图

一、总体结论

阶段性判断：代码审查已确认支付回跳和长任务恢复两个高优先级问题，并确认回调枚举、体积限制、配置文档和 CSP 四项问题。

证据强度：6 个确认项均有文件行号、可执行探针、回归补丁和修复补丁；第 4 阶段仍可能依据规格和部署意图重新分类。

基线结果：当前完整测试基线为 182 项全部通过；类型检查、Lint、生产构建和生产依赖审计均已完成。

二、第 1 阶段：全量探索

覆盖范围：鉴权与权限、视频生成、Provider 路由、AI 回调、QStash 对账、积分账本、Stripe、上传与存储、生成器前后端接口。

规模：672 个 Git 跟踪文件，其中 465 个位于 src；采用 200–500 源文件项目的深度范围声明。

探索产出：14 条带文件行号的事实发现、8 个后续候选项、4 个完整模式走查，入口门槛 13/13 通过。

明确不纳入：营销页面视觉、体验优化、非关键文案，以及遗留 Kubernetes/etcd 模块的深度审计。

第 1 阶段确认的正向防线

- 未登录敏感 API 返回 401，管理员 API 对未授权请求返回 403。
- 管理员权限从数据库实时读取，避免撤权后仍依赖旧 Cookie 缓存。
- 生成入口校验上传图片归属，用户身份由会话得到。
- 前端模型选项与服务器模型能力校验使用共享目录和积分计算逻辑。
- AI 回调具备 HMAC、时间窗口、Provider 与外部任务 ID 绑定。
- 积分冻结、结算和释放具备锁与幂等状态判断。
- 远程媒体已有 HTTPS、私网地址、重定向和字节数限制。

三、当前确认问题与待审项

级别	问题	正常使用影响	追踪
高	Stripe 回跳不存在的 /dashboard	支付可能成功，但成功、取消或 Billing Portal 返回后出现 404。	REQ-009 / BUG-001
高	长任务超过初始对账窗口后可能悬挂	约 7.5 分钟后 workflow 返回 PENDING；若回调丢失且用户不再轮询，视频与冻结积分可能长期非终态。	REQ-005、REQ-007 / BUG-002
中	Provider 回调枚举遗漏 Bailian	Bailian 已在类型、配置和工厂中定义，但通用回调入口拒绝该标识；当前可能因轮询模式而被掩盖。	REQ-011 / BUG-003
中	AI 回调请求体未显式限流	Stripe Webhook 有 1 MiB 上限，AI 回调直接解析 JSON，形成外部入口防御不一致。	REQ-006、REQ-010 / BUG-004
待审	远程媒体 DNS 重绑定窗口	预解析校验与实际 fetch 再次解析之间可能改变目标地址，需要验证部署 HTTP 栈是否已经固定地址。	REQ-010 / Q-001
中	回调密钥文档变量不一致	部分指南写 AI_CALLBACK_SECRET，代码和示例环境实际要求 CALLBACK_HMAC_SECRET。	REQ-012 / BUG-005

低	CSP 阻止 Vercel 观测脚本	Analytics 和 Speed Insights 在浏览器中被 CSP 拦截，影响事故可观测性，不影响核心生成功能。	BUG-006
覆盖缺口	缺少付费生成完整链路测试	现有测试未在同一确定性流程中覆盖会话、冻结、Provider、存储、结算和账户响应。	CAND-008

四、第 2 阶段：质量制品生成

行为契约：提取并归纳 38 条核心行为契约，覆盖权限、生成输入、积分与视频状态、Provider、回调、媒体安全、Stripe 和部署配置。

需求与用例：形成 12 条可测试需求和 7 个端到端用例；每条需求包含代码证据、适用用例和明确满足条件。

质量场景与自动检查：形成 10 个真实故障场景；新增 27 项 Vitest 功能测试并全部通过；机械脚本可重建 Provider 列表并稳定检测 Bailian 回调缺口。

后续执行协议：已生成代码审查、集成测试、规格审计和红绿 TDD 四份执行协议，保证后续阶段按同一证据标准进行。

第 2 阶段验证结果

检查	结果	说明
功能测试	通过	27/27
TypeScript	通过	无类型错误
Lint	通过	376 个文件
机械枚举	通过	提取结果可重复；差集为 bailian
制品门槛	通过	10 个核心制品均存在且非空

五、第 3 阶段：代码审查与回归设计

三轮审查：结构审查、逐需求审查和可执行确认均已完成；12 条需求全部给出满足、违反或待证明结论。

确认结果：确认 BUG-001 至 BUG-006：2 个高、3 个中、1 个低；DNS 重绑定保留为待审问题，完整付费链路保留为覆盖缺口。

模式网格：REQ-005 的 5 个积分状态单元均有补偿；REQ-007 的 2 个耐久对账缺口归入 BUG-002；REQ-011 的 Bailian 缺口归入 BUG-003。

补丁与写案：已生成 6 个预期失败回归补丁、6 个拟议修复补丁和 6 份独立问题写案；12 个补丁全部通过 `git apply --check`。

验证基线：完整测试 182/182 通过，TypeScript 与 Lint 通过，产品源码保持不变。

六、下一阶段计划

第 4 阶段目标：由产品运营、安全财务和实现一致性三个独立视角复核 6 个确认项及 2 个待审项，解决规格与实现冲突。

- 确认 Stripe 应回到 settings、credits 还是其他本地化账户页。
- 确认 Provider 最长允许时长及超时后的失败、继续等待或人工复核政策。
- 明确 Bailian 是轮询专用还是回调漏接，并决定是否需要能力元数据。
- 确认 Vercel 观测组件是否有意启用，以及部署 HTTP 栈是否已阻止 DNS 重绑定。

七、审计文件位置

仓库证据：F:\saas411\quality\

核心入口：EXPLORATION.md、REQUIREMENTS.md、QUALITY.md、CONTRACTS.md、COVERAGE_MATRIX.md、PROGRESS.md。

本总结：C:\Users\Administrator\Desktop\VideoFly 网站全量质量检查阶段总结.docx